

Informe de Cierre de Proyecto: Desarrollo de Software Seguro

Asignatura: ISWZ3206 - Desarrollo de Software Seguro **Proyecto:** Integración Segura de Sistemas (A y B) mediante IAM y KMS

1. Objetivo del Proyecto

Implementar una arquitectura de integración segura entre dos aplicaciones web independientes (Sistema A y Sistema B) que residen en servidores distintos. Esto se logra mediante la centralización de la gestión de identidades utilizando Keycloak y asegurando la confidencialidad de la comunicación a través de un servicio de gestión de llaves de terceros (KMS), garantizando así los principios de confidencialidad, integridad y disponibilidad.

2. Planteamiento del Proyecto (Esquema Ágil)

El proyecto se gestionó bajo el marco de trabajo Scrum, estructurando el desarrollo en 4 Sprints principales.

Roadmap y Planificación de Sprints

- **Sprint 1: Arquitectura y Setup (Semanas 1-2)**
 - Levantamiento de infraestructura aislada para los Sistemas A y B.
 - Despliegue del servidor de identidades (Keycloak).
- **Sprint 2: Gestión de Identidades (Semanas 3-4)**
 - Implementación de Autenticación, Autorización y SSO.
 - Configuración de la Federación de Usuarios.
- **Sprint 3: Criptografía y MFA (Semanas 5-6)**
 - Integración del 2do Factor de Autenticación (App Móvil).
 - Integración de la API de AWS KMS en ambos sistemas.
- **Sprint 4: Auditoría y Despliegue (Semanas 7-8)**
 - Análisis SAST, remediación de vulnerabilidades y revisión de ética algorítmica.

Ejemplo de Historias de Usuario (Estimadas en Puntos de Historia)

- **HU01 (8 pts):** *Como usuario, quiero iniciar sesión una sola vez (SSO) para poder navegar entre el Sistema A y el Sistema B sin tener que reingresar mis credenciales.*
- **HU02 (5 pts):** *Como administrador de seguridad, quiero exigir un código TOTP (2FA) desde una app móvil para asegurar que los accesos sean legítimos.*
- **HU03 (13 pts):** *Como Sistema A, quiero encriptar el payload antes de enviarlo al Sistema B usando una llave del KMS, para que la trama no pueda ser interceptada.*

3. Arquitectura de Control de Identidades (Keycloak)

Se seleccionó **Keycloak** como solución IAM (Identity and Access Management) debido a su robustez y soporte de estándares abiertos.

- **Autenticación y Autorización:** Se implementó el flujo de *OpenID Connect (OIDC)*. Keycloak actúa como el Proveedor de Identidad (IdP). Se definieron roles y políticas de acceso (RBAC) que determinan qué endpoints del Sistema B pueden ser consumidos por un usuario originado en el Sistema A.
- **SSO (Single Sign-On):** Ambos sistemas fueron configurados como "Clientes" dentro del mismo *Realm* en Keycloak. Al iniciar sesión en el Sistema A, Keycloak genera una sesión centralizada y un token JWT; al intentar acceder al Sistema B, el sistema valida la sesión activa, permitiendo el ingreso sin solicitar credenciales nuevamente.
- **2do Factor de Autenticación (MFA):** Se forzó una política de seguridad que requiere OTP (One-Time Password) basado en tiempo (TOTP). Los usuarios deben escanear un código QR en su primer inicio de sesión utilizando Google Authenticator o Authy.
- **Federación de Usuarios:** Keycloak se conectó a un directorio activo externo (LDAP/Active Directory) mediante un proveedor de federación (User Federation Provider). Esto permite que los usuarios inicien sesión con sus credenciales corporativas existentes sin replicar las bases de datos.

4. Integración Criptográfica (KMS)

Para garantizar que el canal de comunicación y los datos en reposo/tránsito sean seguros, la invocación de servicios desde A hacia B se protegió utilizando un Key Management Service (ej. AWS KMS o HashiCorp Vault).

1. **En el Sistema A:** Antes de realizar la petición HTTP hacia el Sistema B, el Sistema A invoca la API del KMS enviando el *plaintext* (o generando una llave de datos de un solo uso). El KMS devuelve la trama cifrada (*ciphertext*).
2. **Tránsito:** La trama viaja encriptada desde el servidor A al servidor B (incluso sobre TLS, añadiendo una capa de cifrado a nivel de aplicación).
3. **En el Sistema B:** Al recibir el *ciphertext*, el Sistema B invoca al KMS con las credenciales correspondientes a su rol. El KMS valida los permisos y devuelve el *plaintext* para que B lo procese.

5. Auditoría de Código (SAST)

Se integró **SonarQube** en el pipeline de CI/CD como herramienta de verificación de código estático para medir y mitigar brechas de seguridad.

- **Resultados Principales:** Se analizaron los repositorios de los Sistemas A y B contra el marco de trabajo OWASP Top 10.
- **Hallazgos Mitigados:** Se detectaron 2 *Security Hotspots* relacionados con la validación de entradas (posible inyección) y 1 advertencia por uso de cifrado obsoleto en una librería heredada. Ambas vulnerabilidades fueron refactorizadas antes de liberar el Sprint 4, logrando un *Security Rating* de grado A.

6. Análisis de un Dilema Ético y Discriminación (Responsabilidad Profesional)

El Dilema de la Fricción de Seguridad vs. Accesibilidad (Brecha Digital) La implementación estricta de políticas de seguridad corporativas, como el uso obligatorio de una aplicación móvil para el 2do Factor de Autenticación (MFA) y los bloqueos automáticos por sistemas adaptativos, presenta un dilema ético profundo. Por un lado, la responsabilidad profesional exige maximizar la protección de los datos de los usuarios frente a ciberataques. Por otro, esta misma política puede resultar discriminatoria y excluyente.

Se corre el riesgo de marginar a usuarios de entornos socioeconómicos vulnerables que no poseen teléfonos inteligentes compatibles, o a personas de la tercera edad con menor alfabetización digital. Asimismo, si Keycloak utiliza heurísticas para detectar "inicios de sesión sospechosos" basados en la ubicación geográfica, existe un claro riesgo de **sesgo algorítmico**. Los algoritmos de prevención de fraude pueden penalizar injustamente a usuarios que se conectan desde regiones rurales o redes de infraestructura precaria, marcándolos erróneamente como amenazas simplemente por no coincidir con el patrón "normal" de un usuario urbano de alta conectividad.

7. Evaluación del Impacto de las Soluciones

La solución implementada tiene impactos multidimensionales que deben ser gestionados:

- **Impacto Tecnológico y Operativo:** La introducción de Keycloak y un KMS externo centraliza la seguridad, pero introduce nuevos puntos únicos de fallo (SPOF) y un incremento en la latencia de red. Si el KMS se cae, el Sistema B es incapaz de procesar las transacciones del Sistema A.
- **Impacto Social y Ético:** Como se analizó en el dilema, la barrera de entrada al sistema se eleva. Para mitigar este impacto negativo y garantizar la equidad, la solución técnica debe ir acompañada de procesos administrativos inclusivos (por ejemplo, ofrecer tokens físicos tipo YubiKey a quienes no tengan smartphones o proveer canales de soporte humano directo para falsos positivos del sistema antifraude).
- **Impacto en la Privacidad:** La federación de identidades centraliza una gran cantidad de PII (Información de Identificación Personal). El impacto de una brecha en el servidor Keycloak sería devastador, lo que justifica la inversión en su fortificación.

8. Planteamiento de Conclusiones

- **La Seguridad como Eje Arquitectónico:** El proyecto demuestra que la seguridad no puede ser añadida al final del ciclo de desarrollo. La integración nativa de SSO y KMS desde el diseño inicial (Security by Design) reduce drásticamente la superficie de ataque entre aplicaciones distribuidas.
- **Delegación Responsable de la Criptografía:** El uso de un KMS de terceros confirma que los desarrolladores no deben implementar ni gestionar sus propios

mecanismos de cifrado y almacenamiento de llaves. Delegar esta responsabilidad a una infraestructura especializada garantiza el cumplimiento de estándares robustos.

- **Juicio Ético Profesional:** Se concluye que la calidad de un software no se mide únicamente por su impenetrabilidad técnica, sino también por su humanidad. Un ingeniero de software responsable debe aplicar **Auditorías de Equidad (Fairness Audits)** a las políticas de seguridad. Las soluciones de ciberseguridad deben diseñarse considerando el impacto en todos los grupos demográficos, asegurando que la protección de la información nunca sirva como herramienta de exclusión digital sistémica.